

Lab 7: Vulnerability Assessment

Objectives	In this practical you will utilize different tools to perform vulnerability scanning as part of vulnerability assessment. CLO: 4 Duration: 60min+
Requirements	▪ Lab PC (or student laptop) ▪ Lab Files
Tasks	▪ Task 1: Security Compliance Scanning –MBSA Alternatives(SolarWinds Network Configuration Manager,Open Vulnerability Assessment System,Nexpose Community Edition,Retina Network Community) ▪ Task 2: Vulnerability Scanning –NESSUS
Vulnerability Assessment	Vulnerability assessment involves discovering weaknesses in the target system. This includes three main tasks: 1) Network Scanning which involves discovering active hosts on a network, 2) Port Scanning (for each discovered host), which involves identifying open ports and running services, and 3) Vulnerability Scanning aimed at identifying vulnerabilities in the system; tools such as MBSA and Nessus automate vulnerability scanning.

SAMEER'S LAB

Task 1: Security Compliance Scanning –MBSA



Task Objectives

- You will use MBSA to scan to scan your personal PC for security compliance vulnerabilities

MBSA



Microsoft Baseline Security Analyzer (MBSA):

“The Microsoft Baseline Security Analyzer provides a streamlined method to identify missing security updates and common security misconfigurations. MBSA 2.3 release adds support for Windows 8.1, Windows 8, Windows Server 2012 R2, and Windows Server 2012.” –Microsoft

MBSA is a security compliance analyzer for Windows.

In 2017, Microsoft announced it will discontinue MBSA and replace it with SCM.

Microsoft Security Compliance Manager 4.0 (SCM):

“This tool provides centralized security baseline management features, a baseline portfolio, customization capabilities, and security baseline export flexibility to accelerate your organization’s ability to efficiently manage the security and compliance process for the most widely used Microsoft technologies.” –Microsoft

1. Download the **Lab Files** from the location specified by your instructor
2. Open the **MBSASetup-x64-EN.msi** installer file and follow the installation process
3. When installation is complete, run MBSA
4. Click the **Scan a computer** link

[Check computers for common security misconfigurations.](#)

The Microsoft Baseline Security Analyzer can check computers running Microsoft Windows computers for security updates utilizes Windows Server Update Services. You must have a



[Scan a computer](#)

Check a computer using its name or IP Address.



[Scan multiple computers](#)

Check multiple computers using a domain name or a range of IP addresses.



[View existing security scan reports](#)

View, print and copy the results from the previous scans.

5. Keep the default computer name (local scan)
Note: for you, the name of the computer will be different so keep it as it is
6. Type your name as the report name

7. Uncheck the IIS and SQL options and click **Start Scan**

Which computer do you want to scan?

Enter the name of the computer or its IP address.

Computer name:

IP address:

Security report name:

%D% = domain, %C% = computer, %T% = date and time, %IP% = IP address

Options:

- ☒ Check for Windows administrative vulnerabilities
- ☒ Check for weak passwords
- ☐ Check for IIS administrative vulnerabilities
- ☐ Check for SQL administrative vulnerabilities
- ☒ Check for security updates
- ☐ Configure computers for Microsoft Update and scanning prerequisites

CONFIDENTIAL

8. When the scan is complete, print the report

Report Details for S P Y D E R - RAVEN (2024-12-06 14:55:55)

Security assessment:
Severe Risk (One or more critical checks failed.)

Computer name: S P Y D E R\RAVEN
IP address: 192.168.8.103
Security report name: S P Y D E R - RAVEN (06-Dec-24 2:55 PM)
Scan date: 06-Dec-24 2:55 PM
Scanned with MBSA version: 2.3.2211.0
Catalog synchronization date:
Security update catalog: Microsoft Update

Sort Order:

Security Update Scan Results

Score	Issue	Result
❌	Developer Tools, Runtimes, and Redistributables Security Updates	1 security updates are missing. What was scanned Result details How to correct this
✅	SQL Server Security Updates	No security updates are missing. What was scanned Result details
✅	Windows Security Updates	No security updates are missing. What was scanned Result details

[Print this report](#) [Copy to clipboard](#) [Previous security report](#) [Next security report](#)

Windows Scan Results

Administrative Vulnerabilities

Score	Issue	Result
❌	Automatic Updates	The Automatic Updates feature has not been configured on this computer. Please upgrade to the latest Service Pack to obtain the latest version of this feature and then use the Control Panel to configure Automatic Updates. What was scanned How to correct this
⚠️	Incomplete Updates	A previous software update installation was not completed. You must restart your computer to finish the installation. If the incomplete installation was a security update, then the computer may be at risk until the computer is restarted. What was scanned How to correct this
⚠️	Password Expiration	Some user accounts (4 of 5) have non-expiring passwords. What was scanned Result details How to correct this
⚠️	Windows Firewall	Windows Firewall is enabled and has exceptions configured. Windows Firewall is enabled on all network connections. What was scanned Result details How to correct this
✅	Local Account Password Test	Some user accounts (3 of 5) have blank or simple passwords, or could not be analyzed. What was scanned Result details
✅	File System	All hard drives (6) are using the NTFS file system. What was scanned Result details
✅	Autologon	Autologon is not configured on this computer. What was scanned
✅	Guest Account	The Guest account is disabled on this computer. What was scanned
✅	Restrict Anonymous	Computer is properly restricting anonymous access. What was scanned
✅	Administrators	No more than 2 Administrators were found on this computer. What was scanned Result details

Additional System Information

9. Fix at least **two** critical issues10. Re-scan but this time, call the report **Fixed –Your Name**

11. Print the second report

Microsoft Baseline Security Analyzer 2.3

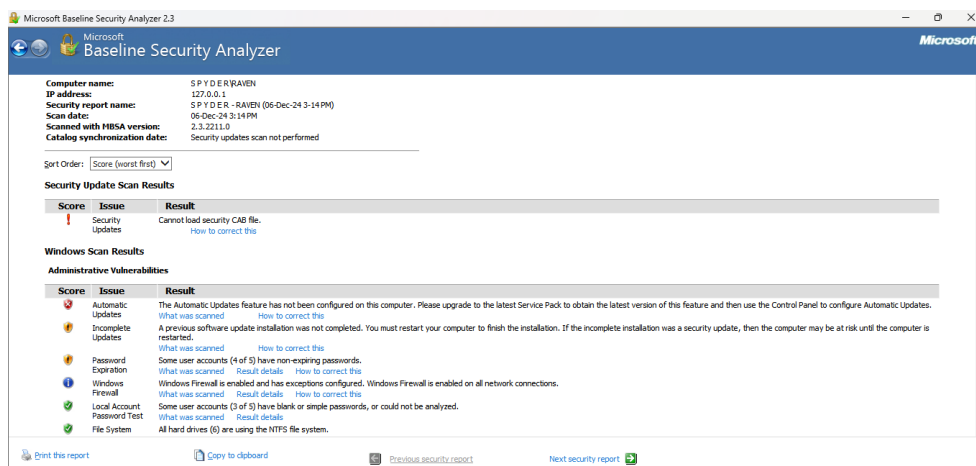
Microsoft Baseline Security Analyzer

Choose a security scan report to view

Security reports are located in: C:\Users\DynaBook\SecurityScans\

Sort order:

Computer Name	IP Address	Assessment	Scan Date
S P Y D E R\RAVEN	127.0.0.1	Incomplete Scan	06-Dec-24 3:14 PM
S P Y D E R\RAVEN	127.0.0.1	Incomplete Scan	06-Dec-24 3:13 PM
S P Y D E R\RAVEN	192.168.8.103	Severe Risk	06-Dec-24 3:08 PM
S P Y D E R\RAVEN	192.168.8.103	Severe Risk	06-Dec-24 2:55 PM



12. Explain the two issues you fixed using the format shown below

Issue 1	
Name	S P Y D E R\RAVEN
ID	
Description	I have the issues of 1. Automatic update 2. In complete updates 3. Password expiration
Steps to Fix	1. I open my window 11 settings of my personal system. 2. In window updates I found the option of advance updates and optional updates. 3. In window option I click the check mark and on it to get latest updates. 4. I get the latest updates of my widow and I install all of them 5. I also install my incomplete updates 6. I change my all credentials which are expire more than a month. I set up all the settings which I need to fix in my first scan of my system.

Issue 2								
Name	S P Y D E R\RAVEN							
ID								
Description	The issues I found in my second scan are: Developer Tools, Runtimes, and Redistributable Security Updates Security Update Scan Results <table><thead><tr><th>Score</th><th>Issue</th><th>Result</th></tr></thead><tbody><tr><td>❌</td><td>Developer Tools, Runtimes, and Redistributables Security Updates</td><td>1 security updates are missing. What was scanned Result details How to correct this</td></tr></tbody></table>		Score	Issue	Result	❌	Developer Tools, Runtimes, and Redistributables Security Updates	1 security updates are missing. What was scanned Result details How to correct this
Score	Issue	Result						
❌	Developer Tools, Runtimes, and Redistributables Security Updates	1 security updates are missing. What was scanned Result details How to correct this						

Steps to Fix	1. I visit the Microsoft Update Web site to install the updates. 2. I register myself with the Microsoft Security Notification Service to ensure you are notified when new security bulletins become available. 3. In results I get all security updates in my system which are latest also. I set up all the settings which I need to fix in my second scan of my system.
---------------------	---

CONFIDENTIAL

Task 2: Vulnerability Scanning –NESSUS



Task Objectives

- You will use Nessus to scan a network PC for vulnerabilities

Nessus



Nessus:

Nessus is a remote security scanning tool, which scans a computer and raises an alert if it discovers any vulnerabilities that malicious hackers could use to gain access to any computer you have connected to a network.

Nessus is a web-based tool (i.e. you access it through your web browser) accessible via the following localhost URL: <https://localhost:8834/#/>

- Go to <https://www.tenable.com/products/nessus-home> and register with your name and college email to get an **activation key**

Register for an Activation Code

First Name *

Last Name *

Email *

☐ Check to receive updates from Tenable

Register

- Download the tool

Download Nessus

To download Nessus, visit the Nessus Download page.

Download

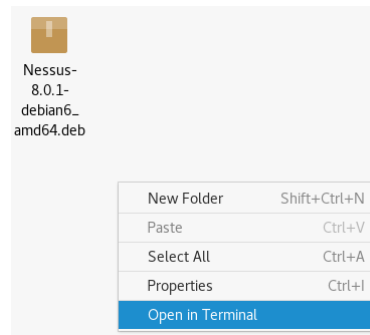
- Scroll until you find the **Debian AMD 64**

Nessus-8.0.1-es6.i386.rpm	Red Hat ES 6 i386(32-bit) / CentOS 6 / Oracle Linux Unbreakable Enterprise Kernel	
Nessus-8.0.1-suse12.x86_64.rpm	SUSE 12 Enterprise (64-bit)	
Nessus-8.0.1-ubuntu910_i386.deb	Ubuntu 9.10 / Ubuntu 10.04 i386(32-bit)	Checksum
Nessus-8.0.1-ubuntu1110_amd64.deb	Ubuntu 11.10, 12.04, 12.10, 13.04, 13.10, 14.04, 16.04 and 17.10 AMD64	Checksum
Nessus-8.0.1-ubuntu1110_i386.deb	Ubuntu 11.10, 12.04, 12.10, 13.04, 13.10, 14.04 and 17.10 i386(32-bit)	Checksum
Nessus-8.0.1-fbsd10-amd64.tgz	FreeBSD 10 and 11 AMD64	Checksum
nessus-updates-8.0.1.tar.gz	Software updates for Nessus Scanners linked to Nessus Managers in 'offline' mode (all OSes/platforms).	Checksum
Nessus-8.0.1-amzn.x86_64.rpm	Amazon Linux 2015.03, 2015.09, 2017.09	Checksum
Nessus-8.0.1-x64.msi	Windows Server 2008, Server 2008 R2*, Server 2012, Server 2012 R2, 7, 8, 10, Server 2016 (64-bit)	Checksum
Nessus-8.0.1-debian6_amd64.deb	Debian 6, 7, 8, 9 / Kali Linux 1, 2017.3 AMD64	Checksum

- Once downloaded, click **Show All Downloads** in your browser
- Click the folder icon to go to the containing folder



6. In the Downloads folder, right-click any empty/white space and click **Open in Terminal**



7. In the terminal window, use the following command to install Nessus:

Sudo dpkg -i Nessus-8.0.1-debian6_amd64.deb

Note: ensure you use the exact name of the .deb package you downloaded



About dpkg:

In Debian, dpkg is a package manager. The -i option is to 'install'

```
root@kalisamer:~/Downloads# dpkg -i Nessus-8.0.1-debian6_amd64.deb
Selecting previously unselected package nessus.
(Reading database ... 341276 files and directories currently installed.)
Preparing to unpack Nessus-8.0.1-debian6_amd64.deb ...
Unpacking nessus (8.0.1) ...
Setting up nessus (8.0.1) ...
Unpacking Nessus Scanner Core Components...
- You can start Nessus Scanner by typing /etc/init.d/nessusd start
- Then go to https://kalisamer:8834/ to configure your scanner
...
CTR : (DRBG) : Pass
IMAC : (DRBG) : Pass
DH : (KAT_KA) : Pass
ECDH : (KAT_KA) : Pass
RSA_Encrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
INSTALL PASSED
Unpacking Nessus Scanner Core Components...
- You can start Nessus Scanner by typing /bin/systemctl start nessusd.service
- Then go to https://kalishezi:8834/ to configure your scanner
```

Nessus Package Installation

8. When the installation is complete, Nessus is started and configured as highlighted above. Type the following command:

/etc/init.d/nessusd start

(or)

/bin/systemctl start nessusd.service

9. Access your Nessus using your web browser

Note: Nessus is accessed using localhost or device name

<https://localhost:8834>

<https://kalisamer:8834>

```
Dec 6 04:45
raven@SPYDER: ~/Downloads
HKDF : (KAT_KDF) : Pass
SSKDF : (KAT_KDF) : Pass
X963KDF : (KAT_KDF) : Pass
X942KDF : (KAT_KDF) : Pass
HASH : (DRBG) : Pass
CTR : (DRBG) : Pass
HMAC : (DRBG) : Pass
DH : (KAT_KA) : Pass
ECDH : (KAT_KA) : Pass
RSA_Encrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
INSTALL PASSED
Unpacking Nessus Scanner Core Components...

- You can start Nessus Scanner by typing /bin/systemctl start nessusd.service
- Then go to https://SPYDER:8834/ to configure your scanner

(raven@SPYDER)-[~/Downloads]
$ /bin/systemctl start nessusd.service

(raven@SPYDER)-[~/Downloads]
$
```

https://spyder:8834/#/ 

Kali Docs  Kali Forums  Kali NetHunter  Exploit-DB  Google Hacking DB  OffSec


Nessus Essentials

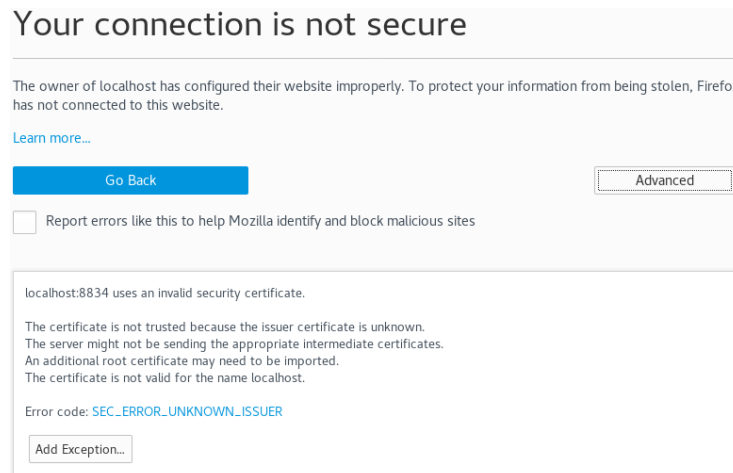
Create a user account

Create a Nessus administrator user account. Use this username and password to log in to Nessus.

Username *

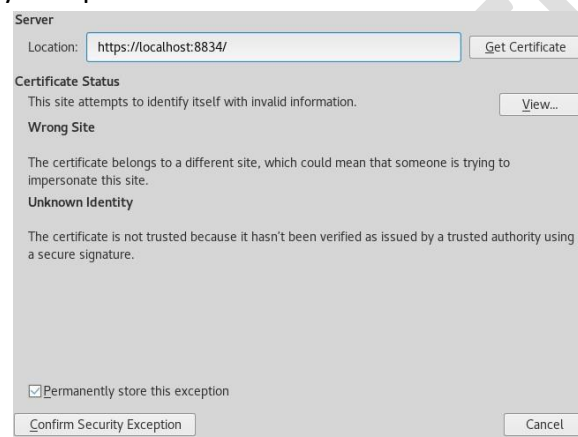
Password *

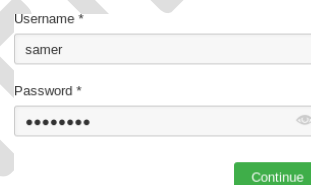


10. Click **Advanced** and **Add Exception** to access your Nessus homepage

11. Confirm the security exception as shown below

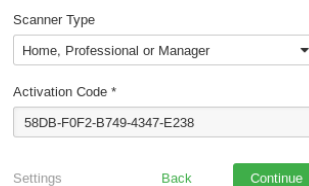


12. Register your local credentials using your **name** and lowercase **password**. Example:

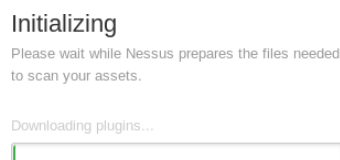


13. Check your email and copy the activation code received from Tenable

14. Click continue and enter your own activation code as shown below

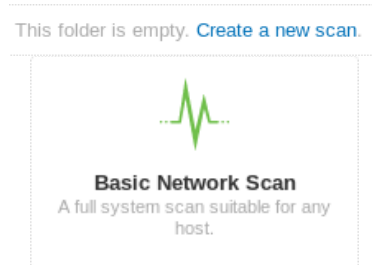


15. After activation, Nessus will download its scan modules and update itself

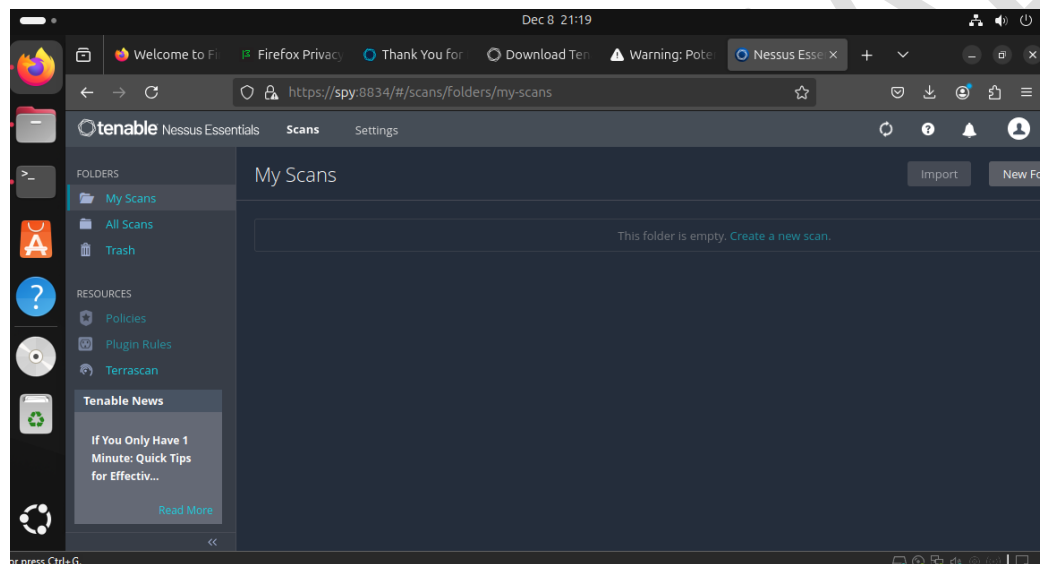


Nessus Initialization

16. Wait for the process to complete, and when done, login
17. Bookmark the Nessus address (add it to your browser favorites)
18. Run your 2 target VMs
19. Click the **Create a new scan** link and select the **Basic Network Scan** option



I have Ubuntu-Linux in my VM Workstation.



20. Enter the scan details targeting your VM's network (use your own network address)

Name	First Scan
Description	Scanning lab's target VMs
Folder	My Scans
Targets	192.168.40.0/24

Scan Details

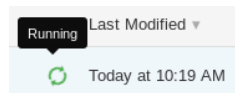
Scan detail of my Target VM.

21. Click **Save** and then **launch** the newly created scan

☐ Name	Schedule	Last Modified	Launch
☐ First Scan	On Demand	N/A	

Launching a Scan

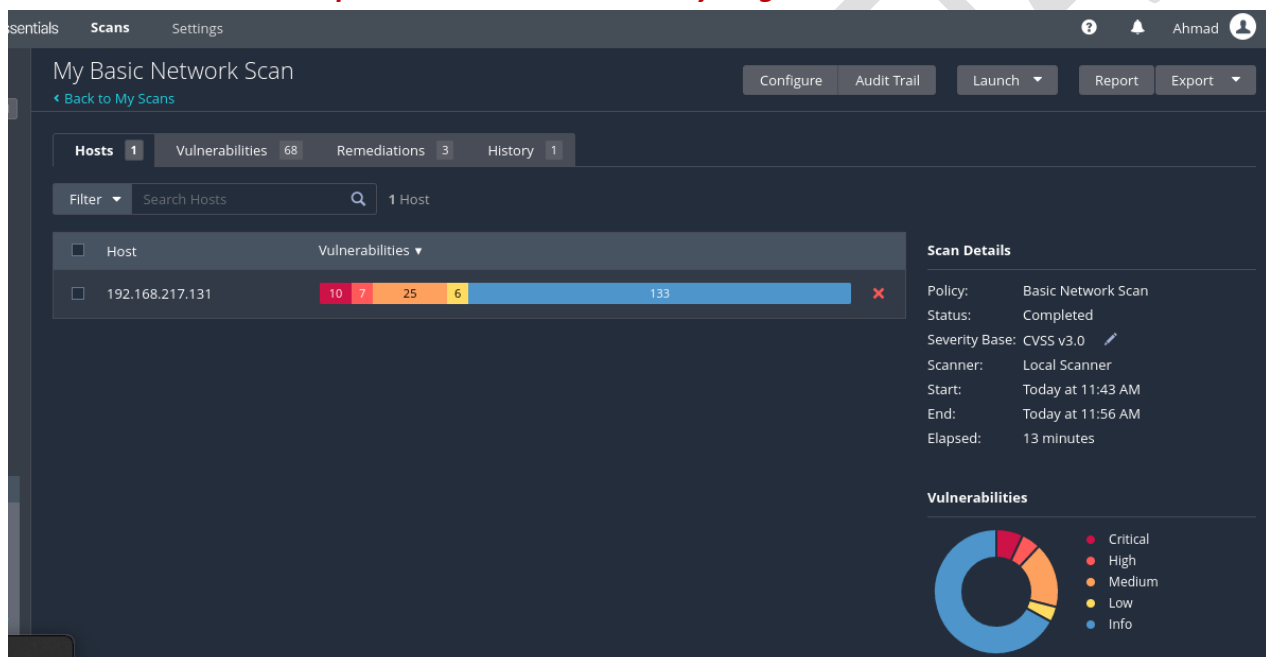
22. Let the scan run. While the scan is running, you can inspect the results as they are reported. Click the **‘running’** icon



23. Click the IP address of one of your target hosts to see its details
24. Go back to the Hosts (scan results) main page and wait for the scan to be completed
25. When the scan is complete, go to the results page and export the results into a PDF
26. Open the PDF file and view its contents

Note: you can print the PDF file and include it in your pen test report for instance

The scan is completed now and I can see my target machine vulnerabilities.



My Basic Network Scan

Configure

Audit Trail

Launch

Report

Export

Hosts1Vulnerabilities68Remediations3History1

Filter

Search Vulnerabilities

68 Vulnerabilities

☐	Sev	CVSS	VPR	EPSS	Name	Family	Count		
☐	CRITICAL	10.0 *	7.4	0.6661	Unr...	Backdoors	1		
☐	CRITICAL	10.0 *			VNC...	Gain a shell remotely	1		
☐	CRITICAL	9.8			Bind...	Backdoors	1		
☐	HIGH	7.5 *	7.4	0.015	rlogl...	Service detection	1		
☐	HIGH	7.5 *	7.4	0.015	rsh ...	Service detection	1		
☐	HIGH	7.5	5.9	0.0358	Sam...	General	1		
☐	HIGH	7.5			NFS ...	RPC	1		
☐	MEDIUM	6.5			Une...	Misc.	1		

Scan Details

Policy:

Basic Network Scan

Status:

Completed

Severity Base:

CVSS v3.0

Scanner:

Local Scanner

Start:

Today at 11:43 AM

End:

Today at 11:56 AM

Elapsed:

13 minutes

Vulnerabilities

Critical

High

Medium

Low

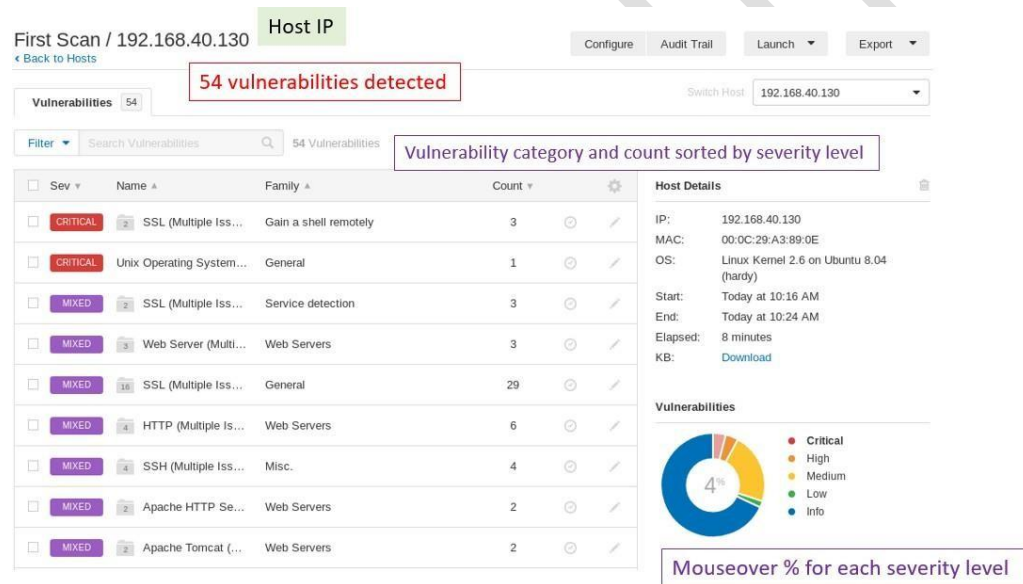
Info

CONFIDENTIAL



Nessus Scan Results

27. Click on the IP address of your Metasploitable VM to see its details



Host-Specific Results

28. Click the first vulnerability category: **SSL (Multiple Issues)**



Vulnerability Family Details

29. Click the first vulnerability to get its details

Vulnerability Plugin#

First Scan / Plugin #32321 Configure Audit Trail Launch Export

[Back to Vulnerability Group](#)

Vulnerabilities 54

CRITICAL Debian OpenSSH/OpenSSL Package Random Number Generator ...

Description

The remote x509 certificate on the remote SSL server has been generated on a Debian or Ubuntu system which contains a bug in the random number generator of its OpenSSL library.

The problem is due to a Debian packager removing nearly all sources of entropy in the remote version of OpenSSL.

An attacker can easily obtain the private part of the remote key and use this to decipher the remote session or set up a man in the middle attack.

Solution

Consider all cryptographic material generated on the remote host to be guessable. In particular, all SSH, SSL and OpenVPN key material should be re-generated.

See Also

<http://www.nessus.org/u?5d01bdab>
<http://www.nessus.org/u?714f4224>

Output

No output recorded.

Port	Hosts
5432 / tcp / postgresql	192.168.40.130
25 / tcp / smtp	192.168.40.130

Name and description

Plugin Details

Severity: Critical
ID: 32321
Version: 1.23
Type: remote
Family: Gain a shell remotely
Published: May 15, 2008
Modified: July 30, 2018

Risk Information

Risk Factor: Critical
CVSS Base Score: 10.0
CVSS Temporal Score: 8.3
CVSS Vector: CVSS2#AV:N/AC:L/Au:N/C:C/I:C/A:C
CVSS Temporal Vector: CVSS2#E:F/RL:OF/RC:C

Risk-related scores

Vulnerability Information

Exploit Available: true
Exploit Ease: Exploits are available
Patch Pub Date: May 14, 2008
Vulnerability Pub Date: May 13, 2008
In the news: true

Exploitability

Exploitable With

Core Impact

Reference Information

CWE: 310
BID: 29179
CVE: CVE-2008-0166

Vulnerability Details

30. Answer the following questions

How long did the scan take?	The scan of my target machine takes 13minutes.
How many hosts were scanned in your first scan?	1 Host –(Metasploit)
How many total vulnerabilities were discovered?	Total vulnerabilities of both target machines are 93.
How many total remediations were provided?	Remediation is 3

How many vulnerabilities were discovered for the XP VM?	25 Vulnerabilities
How many vulnerabilities were discovered for the Metasploitable VM?	68 Vulnerabilities
One of the VMs has a vulnerability of unsupported Web Server. Which VM? What is the unsupported web server? What is the port? How can you access the server?	I haven't found any vulnerability of unsupported web server in XP and Metasploit's.
The server above has web pages for server management and administration. Gain access to those pages and show your instructor	I haven't found any.

CONFIDENTIAL

Review Questions



The following questions are based on the information and activities performed in the activity you just completed.

1. *How many port states does NMAP report and what are they?*

- **Open:** The application on the target is actively accepting connections.
- **Closed:** The port is accessible but has no application listening on it.
- **Filtered:** Nmap cannot determine if the port is open due to a firewall or other network filtering.
- **Unfiltered:** The port is accessible, but Nmap cannot determine if it is open or closed.
- **Open/Filtered:** Nmap cannot determine if the port is open or filtered.
- **Closed/Filtered:** Nmap cannot determine if the port is closed or filtered.

2. *Which one is not part of the vulnerability detection phase of penetration testing?*

- A. Vulnerability scanning
- B. Network scanning
- C. Port scanning
- D. Exploiting vulnerabilities

3. *Which tool can be used to perform a PING sweep?*

- A. HPING3
- B. NMAP
- C. Ping Sweeper
- D. All of the above

4. *What is the default destination port in HPING3?*

- A. Random
- B. 800
- C. 0
- D. 65535

5. *What is the default source port in HPING3?*

- A. 90
- B. 80
- C. Random
- D. 0
- D. 65535

6. *What command is used to save the output of an NMAP scan into a file called results on the target <__ target ip____>?*

➤ `nmap -oN results <target IP>`